

AWS_7_8

接近の制御

接近の制御はまず、対象が適しているかを判断する。

その基準はIP、Protocol、Port番号になる。

AWSにはネットワーク インフラ保護のためセキュリティグループとACLがある。

両方とも、IP、Protocol、Port番号によって接近制御を行う。

違い点を言うと、セキュリティグループはインスタンスレベルの制御をする。

ACLはサブネットのレベルを制御する。

VPC Flow Log

VPC Flow LogはVPCに属するネットワークインタフェースで見えるトラフィックの情報を集めることができること。

스택 세부 정보 시성

스택 이름 제공

스택 이름

CloudFormation-SEC

스택 이름은 문자(a~z, A~Z), 숫자(0~9) 및 하이픈(-)만 포함해야 하며 문자로 시작해야 합니다. 최대 128

파라미터

파라미터는 템플릿에서 정의되며, 이를 통해 스택을 생성하거나 업데이트할 때 사용자 지정

KeyName

Name of an existing EC2 KeyPair to enable SSH access to the instances. Linked to AWS Param

example_key_pair

CloudFormation Stack生成

보안 그룹 (1/15) 정보

속성 또는 태그로 보안 그룹 찾기

Name	보안 그룹 ID	보안 그룹 이름	VPC ID	설명
-	sg-054feac4546401a45	default	vpc-0c33109ce326c6f50	default VPC se
My-SG	sg-02dffa24e240fa3f3	Cloud-example-MySG-LZYpyQmTFBwz	vpc-0c33109ce326c6f50	Enable HTTP a
☒ Server-SG	sg-08416d8f2e65471f8	CloudFormation-SEC-ServerSG-AbkfOiE...	vpc-0a7e7cbc9e6b1f799	Server1 Securit

아웃바운드 규칙 (1)

태그 관리

아웃바운드 규칙 편집

아웃바운드 규칙 정보

보안 그룹 규칙 ID	유형	프로토콜	포트 범위	대상	설명 - 선택 사항
sgr-0080370b9b7b399c8	모든 트래픽	전체	전체	사용자 ...	0.0.0.0/0

セキュリティグループでOutBound規則を編集→削除

☒ Server-SG sg-08416d8f2e65471f8 CloudFormation-SEC-ServerSG-AbkfOiE... vp

아웃바운드 규칙 정보
 보안 그룹 규칙 ID 유형 프로토콜 포트 범위 대상 설명 - 선택 사항 삭제

- HTTP TCP 80 Anywh... 0.0.0.0/0 0.0.0.0/0 ✕

そのため、セキュリティグループからOutbound規則追加

```
[ec2-user@Server-EC2 ~]$ curl ifconfig.me
43.202.6.254[ec2-user@Server-EC2 ~]$
```

接近すると、このようにできる

VPC Flow Log 確認

☐	Name	VPC ID	상태	퍼블릭 액세스...	IPv4 CIDR	플로우 로그 생성
☐	CloudNeta-VPC	vpc-0b7d82adbfc687560	Available	끄기	10.0.0.0/16	VPC 설정 편집
☒	My-VPC	vpc-0c33109ce326c6f50	Available	끄기	20.0.0.0/16	CIDR 편집

VPCからFlow Log 生成

<https://ongja.notion.site/CNBA71-VPC-IAM-6029e5e1e79c4261ac791b447d211304>
 VPC Log 情報を集めるため、IAM政策を生成

내용

플로우 로그 데이터를 게시할 대상입니다.

- ☒ CloudWatch Logs로 전송
- ☐ Amazon S3 버킷으로 전송
- ☐ 같은 계정에서 Amazon Data Firehose로 전송
- ☐ 다른 계정에서 Amazon Data Firehose로 전송

대상 로그 그룹 | 정보

기존 로그 그룹의 이름 또는 이 흐름 로그를 만들 때 생성될 새 로그 그룹의 이름입니다. 모니터링되는 각 네트워크 인터페이스에 대해 새 로그 스트림이 생성됩니다.

🔍 Ongja-Log-Group

CloudWatch 콘솔에서 이 로그 그룹 보기

서비스 액세스

VPC 흐름 로그에는 CloudWatch에서 로그 그룹을 생성하고 이벤트를 게시할 수 있는 권한이 필요합니다.

- ☒ 기존 서비스 역할 사용
- ☐ 새 서비스 역할 생성 및 사용

서비스 역할 | 정보

Amazon CloudWatch 로그 그룹에 게시할 권한이 있는 IAM 역할입니다.

Ongja-FlowLog-Role

IAM 콘솔에서 이 서비스 역할 보기

VPC Log Flow生成

플로우 로그 (1/1)

🔍 검색

트래픽 유형

대상 유형

대상 이름

전체

cloud-watch-logs

Ongja-Log-Group

Log Flowの対象名前

Ongja-Log-Group

작업

Logs Insights에서 보기

테일링 시작

로그 그룹 검색

로그 그룹 세부 정보

로그 클래스 | 정보
표준

ARN
arn:aws:logs:ap-northeast-2:084375569325:log-group:Ongja-Log-Group:*

생성 시간
12분 전

보존
만기 없음

저장된 바이트
-

지표 필터
0

구독 필터
0

기여자 인사이트 규칙
-

KMS 키 ID
-

삭제 보호
끄기

데이터 보호
-

민감한 데이터 개수
-

사용자 지정 필드 인덱스
구성

트랜스포머
구성

이상 탐지
구성

베어러 토큰 인증
끄기

Syslog 수집 | 정보
구성

로그 스트림

태그

데이터 보호

이상 탐지

지표 필터

구독 필터

기여자 인사이트

필드 인덱스

트랜스포머

로그 스트림 (0)

기본적으로 가장 최근의 로그 스트림만 로드합니다.

🔄

삭제

로그 스트림 생성

모든 로그 스트림 검색

Log情報を見ることができる。



사이트에 연결할 수 없음

43.202.6.254에서 응답하는 데 시간이 너무 오래 걸립니다.

HTTP接続をすると、不可能になる。

これは、SSH規則だけあってHTTPはないのでこうなる。

☒	Server-EC2	i-04ea1d855732db875	실행 중	🔍 🔍	t2.micro
☐	Server-EC2-2	i-091682b72425378b2	실행 중	🔍 🔍	t2.micro

i-04ea1d855732db875 (Server-EC2)

▼ 네트워크 인터페이스 (1) 정보

🔍 네트워크 인터페이스 필터링

인터페이스 ID	디바이스 인...	카드 인덱스	설명
eni-0d3fe5e970472747d	0	0	-

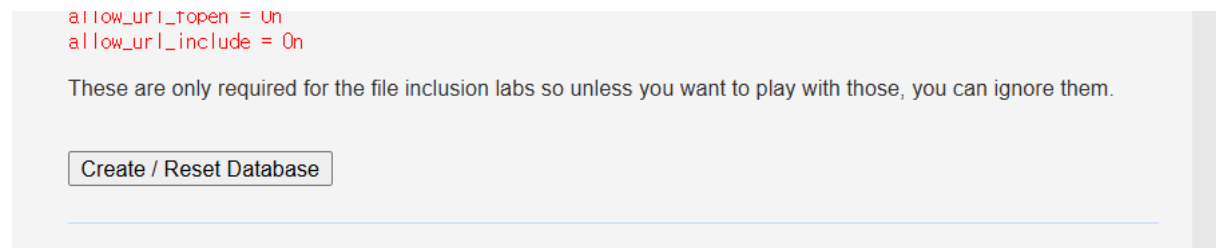
接続失敗を見るためにネットワークインターフェース確認

WAFを通じたウェブアプリケーションのセキュリティ



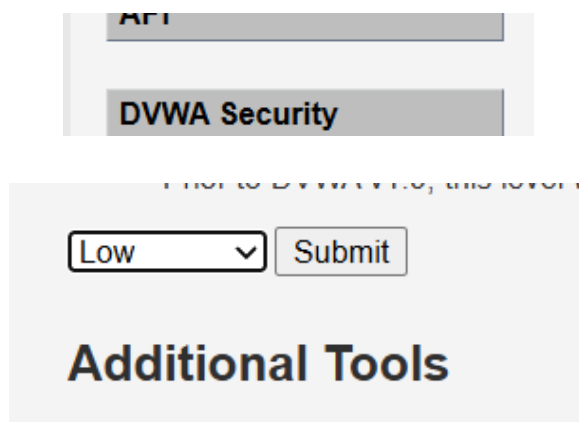
The image shows the DVWA (Damn Vulnerable Web Application) login page. At the top is the DVWA logo, which consists of the letters 'DVWA' in a bold, dark blue font, with a green and blue swoosh graphic to the right. Below the logo are two input fields: 'Username' and 'Password'. The 'Username' field is a simple text box, and the 'Password' field is a text box with a small eye icon to its right, indicating a toggle for password visibility. Below these fields is a 'Login' button.

DVWAインスタンスに接近



The image shows a configuration page for DVWA. It contains two lines of red text: `allow_url_fopen = On` and `allow_url_include = On`. Below this text is a paragraph: "These are only required for the file inclusion labs so unless you want to play with those, you can ignore them." At the bottom of the page is a button labeled "Create / Reset Database".

Create / Reset Database



The image shows the DVWA Security page. It features a dropdown menu with "Low" selected and a "Submit" button. Below this is a section titled "Additional Tools".

セキュリティ段階をLowに変更

Vulnerability: SQL Injection

User ID:

ID: 1`OR 1=1#
First name: admin
Surname: admin

SQL Injection攻撃（ユーザーのIDに関するけっかを見ることができる。

Vulnerability: Command Injection

Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection

Ping a device

Enter an IP address:

PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=108 time=17.7 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=108 time=17.9 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=108 time=17.7 ms
64 bytes from 8.8.8.8: icmp_seq=4 ttl=108 time=18.0 ms

--- 8.8.8.8 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 17.720/17.865/18.047/0.175 ms

Command Injection攻撃（Pingテストの結果、ウェブサーバーの情報が露出する。

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?

More Information

- <https://owasp.org/www-community/attacks/xss/>
- <https://owasp.org/www-community/xss-filter-evasion-cheatsheet>
- https://en.wikipedia.org/wiki/Cross-site_scripting
- <https://www.cgisecurity.com/xss-faq.html>
- <https://www.scripalert1.com/>

3.35.134.151 내용:

PHPSESSID=v8scfr9mqkamqah71bpb4mm4b6; security=low



XSS 공격 (<script>alert(document.cookie)</script>을 입력すると、Cookie値がでる。)

WAF生成

WAF 및 실드

▼ AWS WAF

보호 팩(웹 ACL) New

보호 팩(웹 ACL) (0) 정보

작업 ▼

보호 팩(웹 ACL) 생성

보호 팩(웹 ACL)을 사용하면 위협으로부터 인프라를 보호하는 규칙과 규칙 세트를 결합할 수 있습니다.

MY-ACL에 대한 규칙 관리

< MY-ACL

규칙은 규칙 우선 순위 오름차순으로 표시됩니다.

규칙 추가

이 페이지에는 0개의 규칙이 있습니다.

AWS 관리형 규칙 그룹



AWS 관리형 규칙은 보안 전문가가 유지 관리하는 사전 구성된 규칙 그룹을 사용하여 웹 익스플로잇과 봇 트래픽으로부터 보호합니다.

Core rule set

용량: 700

SQL database

용량: 200



Core rule set, SQL database 規則追加

MY-ACL에 대한 규칙 관리



< MY-ACL

규칙은 규칙 우선 순위 오름차순으로 표시됩니다.

AWS-AWSManagedRulesCommonRuleSet

700 WCU



AWS-AWSManagedRulesSQLiRuleSet

200 WCU



✔ 저장됨

また攻撃すると、403Forbiddenがでる。